



西安电子科技大学
XIDIAN UNIVERSITY

《操作系统》

第八章 操作系统安全



人工智能学院

一、操作系统安全概述

□ 操作系统是计算机软件的基础，它直接与硬件设备进行交互，处于软件系统的最底层。操作系统的安全性在计算机系统的整体安全性中具有至关重要的基础作用，是整个网络信息安全的基石

□ 操作系统安全

□ 操作系统设计安全

□ 操作系统使用安全

一、操作系统安全概述

- 操作系统安全的主要目标是：
 - 按系统安全策略对用户的操作进行访问控制，防止用户对计算机资源的非法访问（窃取、篡改和破坏）；
 - 实现用户标识和身份认证；
 - 监督系统运行的安全性；
 - 保证系统自身的安全性和完整性。

一、操作系统安全概述

□ 操作系统安全的概念

□ 隔离控制

□ 访问控制

□ 最小特权管理

□ 日志与审计

□ 标识与鉴别

□ 可信路径

□ 隐蔽信道和后门

□ 访问监视器和安全内核

□ 可信计算基

□ ...

一、操作系统安全概述

□ 操作系统安全的概念

- **隔离控制**：将系统内不同用户、进程、资源隔开，像**物理隔离**(不同终端分区)、**逻辑隔离**(通过软件划分不同安全域)，避免一个部分出问题影响其他，比如把企业财务系统和普通办公系统隔离，保护财务数据
- **访问控制**：依据规则决定用户/进程能否访问资源，有**自主访问控制**（用户可自主设置资源权限）、**强制访问控制**（系统按安全策略强制管控），比如限制普通员工访问服务器核心配置文件
- **最小特权管理**：给用户、进程分配完成任务所需最小权限，**减少权限滥用风险**，比如软件更新进程仅获更新必要文件的权限，而非全盘访问权
- **日志与审计**：日志记录系统操作（用户登录、文件修改等），审计则分析日志找异常，用于**追溯安全事件、核查违规操作**。例如通过日志发现某账户深夜频繁访问敏感数据就可能有问题
- **标识与鉴别**：标识是给用户/实体**分配唯一身份**（如用户名、设备ID），鉴别是验证身份真实性，常用密码、生物特征（指纹、人脸）、数字证书等，确保操作是合法主体发起

一、操作系统安全概述

□ 操作系统安全的概念

- **可信路径**：在用户与系统安全关键组件（如登录验证模块）间**建立可靠通信通道**，防止被篡改、窃听，比如登录系统时，确保输入的账号密码直接传至认证模块，不被恶意程序截获
- **隐蔽信道和后门**：隐蔽信道是违规传递信息的隐藏途径，比如利用系统空闲资源编码传输敏感数据；后门是开发者或攻击者预留的未授权访问入口，**都威胁系统安全**，需检测封堵
- **访问监视器和安全内核**：访问监视器是验证访问请求是否合规的组件，依据安全策略判断；安全内核是操作系统中实现安全机制的核心部分，小巧且功能关键，保障基础安全策略执行
- **可信计算基**（TCB, Trusted Computing Base）：系统中用于**实施安全策略、保护系统安全的所有硬件、软件、固件的集合**，是安全的基础依托，其自身需安全可靠，通过评估TCB可衡量系统安全等级

一、操作系统安全概述

□ 操作系统安全配置

- 操作系统访问权限的恰当设置

最小权限原则。 为每个用户和应用严格分配所需的最小权限，禁用默认高危账户，并强制使用强密码，从源头上减少被滥用的风险。

- 操作系统的及时更新问题

消除已知漏洞。 建立自动化或受控的补丁管理策略，确保系统、驱动和关键应用及时获得安全更新，有效防御针对已知漏洞的攻击。

- 利用系统功能有效防范外界攻击

构筑纵深防线。 充分利用系统内置的防火墙、防病毒、加密和入侵检测等功能，形成多层防护，实现从网络到本机的主动防御。

一、操作系统安全概述

□ 开发一个安全的操作系统可分为四个阶段：



- **建立安全模型**：先**明确**操作系统要实现的安全目标（如数据保密、用户权限管控），把这些需求转化为可遵循的安全规则框架，像定义哪些操作合法、不同用户能访问啥资源，是开发安全系统的“蓝图”
- **系统设计**：依据安全模型，**规划系统的架构、模块功能**，比如设计权限管理模块咋工作、进程咋隔离，把安全需求变成具体可开发的设计方案
- **可信度检查**：开发中/完成后，**验证**系统是否符合安全模型，找设计或代码里的安全漏洞，确保系统按安全要求构建，像检查权限控制是否有漏洞、数据加密是否到位
- **系统实现**：把设计好的内容用代码等**实现**，**部署**成能实际运行的操作系统，让安全设计落地，同时解决开发和运行中的兼容性、性能等问题

一、操作系统安全概述

□ 操作系统安全设计原则

□ 隔离性：解决最少通用机制的问题

□ 内核机制：解决最少权限及经济性的问题

□ 分层结构：解决开放式设计及整体策划的问题

一、操作系统安全概述

- 通用操作系统一般具有如下安全性服务及其需要的基本特征。
 - 安全登录
 - 自主访问控制
 - 安全审计
 - 内存保护
- Windows操作系统通过它的安全性子系统和相关组件来达到这些需求，并引入了一系列安全性术语

二、Windows操作系统安全

□ Windows 操作系统安全历程

一、早期Windows版本（1.0-3.0）：基础功能与安全雏形

- **Windows1.0（多进程）**
 - 1985年发布，引入进程隔离概念，防止单个程序崩溃影响整个系统
 - 权限管理极弱，普通程序可随意访问系统资源
- **Windows2.0（386扩展模式）** ——依托英特尔80386处理器的“32位保护模式”
 - 首次区分内核态与用户态
 - 限制普通程序直接篡改系统核心资源
- **Windows3.0（虚拟设备驱动VxDs）** ——VxDs（Virtual Device Drivers）
 - 通过标准化驱动接口管理硬件访问
 - 限制驱动漏洞的影响范围

二、Windows操作系统安全

□ Windows 操作系统安全历程

二、Windows 7：安全体系化升级（应对互联网威胁）

- **SDL（安全开发生命周期）**

- 将安全流程融入代码开发
- 从源头减少缓冲区溢出等漏洞

- **NX保护+ASLR**

- NX（No Execution, 不可执行）：阻止数据区执行恶意代码
- ASLR（地址空间布局随机化）：随机化内存地址，增加攻击难度

- **权限保护**

- UAC（用户账户控制）要求管理员确认系统更改
- 阻止恶意软件静默安装

- **主动防御与数据保护**

- 安全中心统一管理防护功能
- BitLocker提供全盘加密保护
- EFS（加密文件系统）针对单个文件/文件夹加密

二、Windows操作系统安全

□ Windows 操作系统安全历程

三、Windows 10：虚拟化与密码安全深化

- 基于虚拟化的安全（VBS）

- 在独立虚拟环境中运行安全功能
- 保护密码验证等敏感数据不被内核漏洞窃取

- 密码管理与抗攻击强化

- 采用更安全的哈希算法
- 防御凭据窃取和Pass-the-Hash攻击

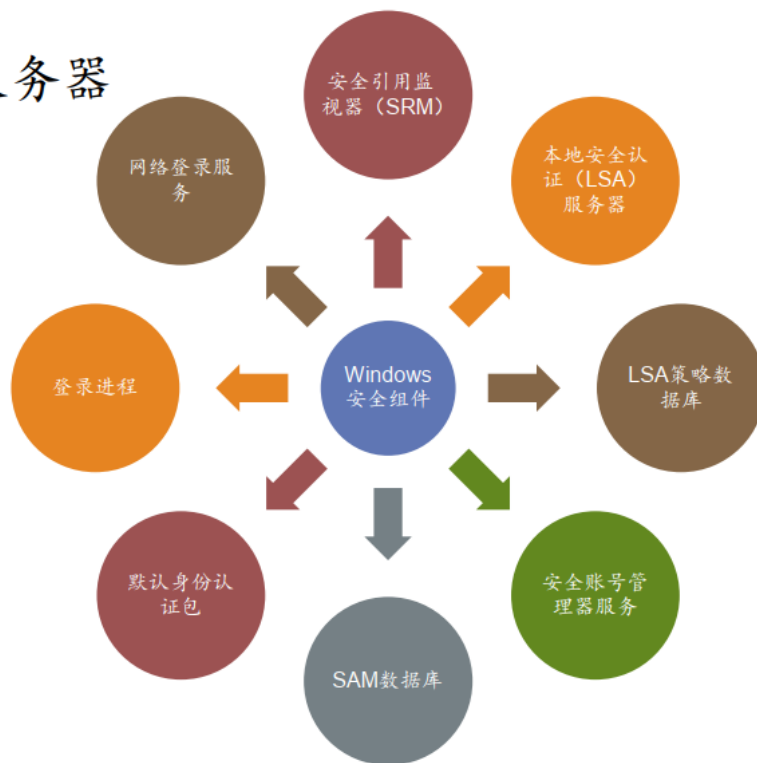
四、Windows Server：面向企业级的安全特化

- 多用户隔离：通过虚拟机实现租户业务隔离
- 合规适配：满足GDPR（欧盟数据保护法案）、等保2.0等标准要求
- 高可用防护：防御DDoS（分布式拒绝服务）攻击和勒索病毒，支持异地备份

二、Windows操作系统安全

□ Windows的安全性组件

- 安全引用监视器 (SRM)
- 本地安全认证 (LSA) 服务器
- LSA策略数据库
- 安全账号管理器服务
- SAM数据库
- 默认身份认证包
- 登录进程
- 网络登录服务



二、Windows操作系统安全

□ Windows操作系统的用户登录过程

□ 登录进程 (WinLogon)

□ LSA

□ 身份认证包

□ SAM的相互作用进行的



二、Windows操作系统安全

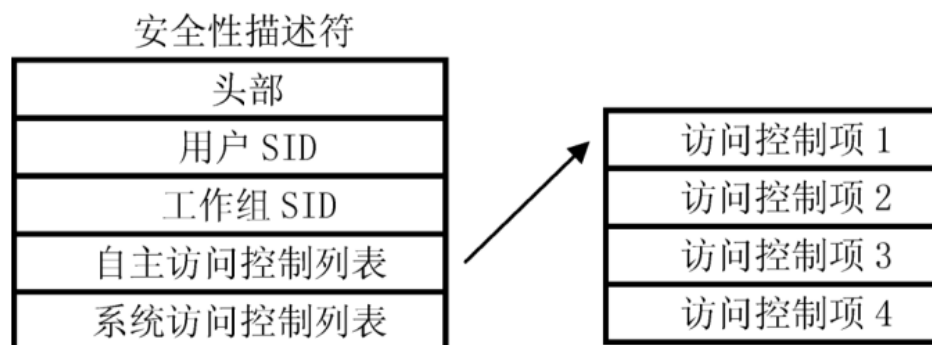
□ 安全性描述符

□所有者SID (Security Identifiers, 安全标识符)

□组SID

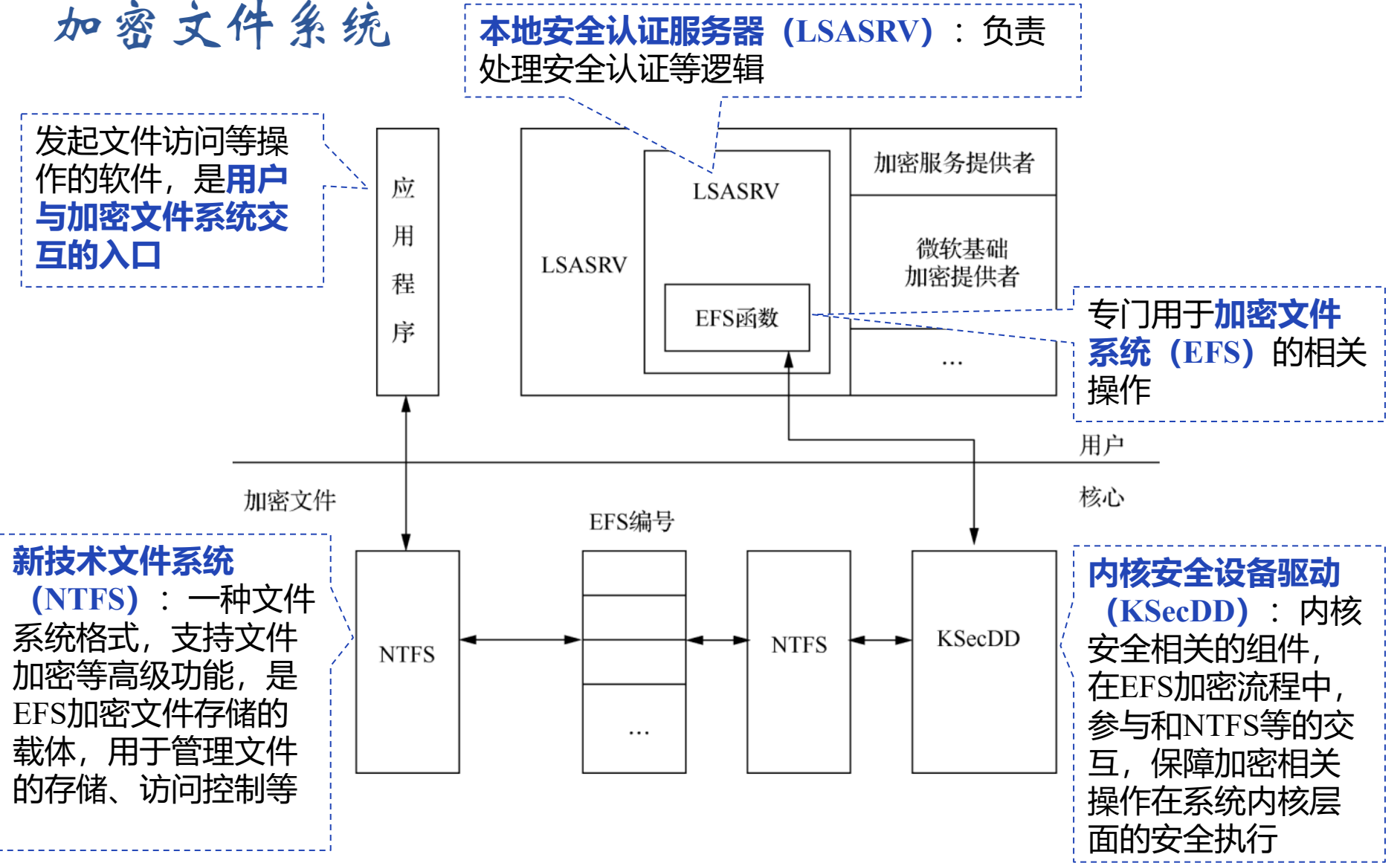
□自主访问控制列表 (DACL)

□系统访问控制列表 (SACL)



二、Windows操作系统安全

加密文件系统



二、Windows操作系统安全

Windows操作系统的资源访问

- Windows操作系统的资源对象包括文件、设备、邮件槽、已命名的和未命名的管道、进程、线程、事件、互斥体、信号量、可等待定时器、访问令牌、窗口站、桌面、网络共享、服务、注册表键和打印机
- 资源访问
 - 安全性描述符和访问控制
 - 访问令牌与模仿
 - 加密文件系统

二、Windows操作系统安全

Windows操作系统的安全审计

- 在Windows操作系统中，对象管理器可以将访问检查的结果生成审计事件
- 用户使用有效的Win32函数也可以直接生成这些审计事件
- 核心态代码通常只允许生成一个审计事件

二、Windows操作系统安全

Windows操作系统的安全审计

□ Windows操作系统在运行中产生三类日志：

- **系统日志 (System Log)** ——记录系统组件（如服务、驱动）的运行情况
 - **典型场景**：系统启动时，记录“哪个驱动加载失败”；自动更新时，记录“补丁安装成功/失败”；硬件出问题时，记录“硬盘SMART检测报警”
- **应用程序日志(Application Log)**——记录安装在系统里的应用程序产生的日志（程序开发者决定记什么）
 - **典型场景**：浏览器崩溃时，记录“崩溃时加载的网页、插件”；办公软件保存文件失败时，记录“错误代码、哪步出错”；游戏启动时，记录“显卡驱动版本、资源加载情况”
- **安全日志 (Security Log)** ——记录和“安全审计事件”强相关，专门存资源访问、权限变更、登录登出这类安全事件
 - **典型场景**：有人尝试暴力破解密码，记录“登录失败次数、IP地址”；管理员修改了文件权限，记录“谁改了权限、改成了什么”；程序访问敏感文件夹，记录“哪个程序、什么时候访问的”

三、Linux安全

▣ Linux从UNIX和POSIX中继承了最基本的安全机制：

▣ 用户

▣ 文件权限

▣ 进程的Capabilities的管理

▣ 其他：安全增强Linux（SELinux）、域和类型增强（DTE）以及Linux入侵检测系统（LIDS）等

三、Linux安全

□ Linux操作系统的安全机制

□ 1. PAM机制

□ 2. 身份验证

□ 3. 访问控制

□ 4. 安全审计

□ 5. 加密文件系统

□ 6. 程序角色切换

□ 7. 内存管理

□ 8. 客体重用

□ 9. 防火墙

□ 10. 入侵检测系统

□ 11. 扫描检测工具

提高Linux操作系统安全的策略

▣ 系统安装及启动登录

- ▣ 尽量安装最少的模块，然后再根据需要添加必要的服务软件。
因为安装的服务越少，出现安全漏洞的概率就越小，相应的系统安全性就越高
- ▣ 安装时尽量根据角色划分多个分区
- ▣ 设置BIOS密码且修改启动时的引导次序，禁止从软盘启动；
- ▣ 修改文件/etc/inetd.conf，使得其他系统登录到本系统时不显示操作系统和版本信息，增强系统的安全性
- ▣ 经常访问Linux技术支持网站，下载最新的补丁安装程序并及时安装，修补系统的安全漏洞

三、Linux安全

提高Linux操作系统安全的策略

▣ 用户账号密码管理和登录

- ▣ 安装系统时默认的密码长度为5，最好将最短密码长度修改为8。操作员（尤其是root用户）在退出系统时应及时注销账号，如果操作员退出时忘记注销，系统应能自动注销。
- ▣ 在系统建立一个新用户时，应根据需要赋予该用户账号不同的安全等级，并且归并到不同的用户组中。例如，除了一些重要的用户外，建议屏蔽掉其他用户的Telnet权限，这样就可以防止入侵者利用其他账号登录系统。
- ▣ Linux提供了许多默认账号，而账号越多系统就越容易受到攻击，因此可以用删除不必要的账号。禁止普通用户切换为root用户。

三、Linux安全

提高Linux操作系统安全的策略

□ 文件管理

- 对重要的文件进行加密处理来予以保护。为了确保安全，操作系统应把不同的用户目录分隔开来。每个用户都有自己的主目录和硬盘空间，这块空间与操作系统区域的其他用户空间分隔开。这样一来，就可以防止普通用户的操作影响整个文件系统
- 使用chown或chgrp 命令正确设置文件的所有权或用户组关系，提高文件访问的安全性

三、Linux安全

提高Linux操作系统安全的策略

▣ 防御技术

- ▣ 通过设置可以防止Ping攻击、IP欺骗、DoS攻击；
- ▣ 定期审查日志信息；
- ▣ 设置防火墙、入侵检测系统；
- ▣ 进行病毒防护；
- ▣ 做好数据备份。

谋成于密，败于泄。

三军之事，莫重于秘。

——《兵经百言》